

Security+ 2.4 · Replay Attacks

Mestre CyberSec — PDF baseado na aula do Professor Messer · 2.4 — Replay Attacks (5:45) · [vídeo original](#)
[↗](#) · [YouTube](#) [↗](#)

Replay: capturar o handshake/token e REENVIAR pra se autenticar de novo. Pass-the-hash: usar o HASH da senha como autenticador direto NTLM (Mimikatz + PsExec) — movimento lateral. Session hijacking: roubar cookie de sessão ativa (via XSS ou on-path) e se passar pelo usuário. Defesa: nonce/timestamp, TLS, HttpOnly cookie, session token com expiração.

💡 Highlights que a prova cobra

- Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp
- Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos
- Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga

🎯 Dicas de prova

- 'reuses captured authentication data' = replay attack
- 'uses an NTLM hash to authenticate' = pass-the-hash

Cenário clássico: Cenário: 'atacante captura o hash NTLM da memória e usa pra logar em outros sistemas' = pass-the-hash.

✅ Perguntas de treino (10 questões)

Gabarito no fim. Tenta responder SEM olhar.

1. Atacante se posiciona entre duas partes e intercepta/altera a comunicação. Isso é:
- A)** Ataque on-path (MITM)
 - B)** Negação de serviço
 - C)** SQL injection
 - D)** Força bruta

2. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

3. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

4. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

5. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'reuses captured authentication data' = replay attack'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: 'reuses captured authentication data' = replay attack...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

6. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'uses an NTLM hash to authenticate' = pass-the-hash'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: 'uses an NTLM hash to authenticate' = pass-the-hash...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

7. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Cenário: 'atacante captura o hash NTLM da memória e usa pra logar em outros sistemas' = pass-the-hash.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Cenário: 'atacante captura o hash NTLM da memória e usa pra logar em outros...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

8. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp...

9. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

10. Cenário corporativo (Replay Attacks): Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.4), um analista avalia o seguinte requisito técnico: 'Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

GABARITO COMENTADO

1) A — Ataque on-path (MITM). On-path (antigo 'man-in-the-middle') = fica no meio do tráfego lendo/alterando. DoS derruba serviço; SQLi injeta comando no banco; força bruta testa senhas.

2) A — Implementar a solução correspondente: Replay: reenvia o 'handshake' capturado — . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp. As demais alternativas configuram violações graves

3) C — Implementar a solução correspondente: Pass-the-hash: usa O HASH (não a senha) — . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos. As demais alternativas configuram violação

4) B — Implementar a solução correspondente: Session hijacking: rouba cookie — HttpOnly. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga. As demais alternativas configuram violações graves de confo

5) B — Implementar a solução correspondente: 'reuses captured authentication data' = re. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): 'reuses captured authentication data' = replay attack. As demais alternativas configuram violações graves de conformid

6) C — Implementar a solução correspondente: 'uses an NTLM hash to authenticate' = pass. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): 'uses an NTLM hash to authenticate' = pass-the-hash. As demais alternativas configuram violações graves de conformidad

7) A — Implementar a solução correspondente: Cenário: 'atacante captura o hash NTLM da . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): Cenário: 'atacante captura o hash NTLM da memória e usa pra logar em outros sistemas' = pass-the-hash.. As demais alte

8) D — Implementar a solução correspondente: Replay: reenvia o 'handshake' capturado — . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): Replay: reenvia o 'handshake' capturado — defesa: nonce/timestamp. As demais alternativas configuram violações graves

9) C — Implementar a solução correspondente: Pass-the-hash: usa O HASH (não a senha) — . Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): Pass-the-hash: usa O HASH (não a senha) — NTLM é vulnerável, Kerberos menos. As demais alternativas configuram violação

10) B — Implementar a solução correspondente: Session hijacking: rouba cookie — HttpOnly. Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.4 (Replay Attacks): Session hijacking: rouba cookie — HttpOnly + HTTPS mitiga. As demais alternativas configuram violações graves de confo

